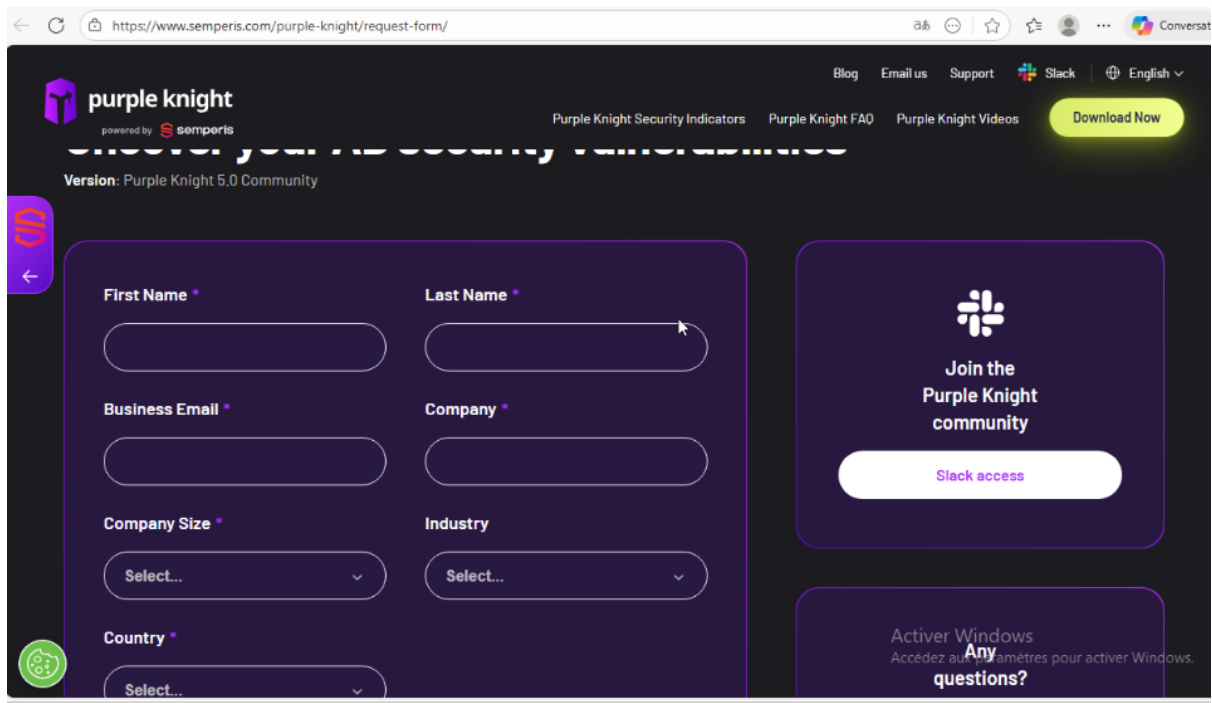


# Audit de Sécurité Active Directory avec Purple Knight

## 1. Introduction à l'outil

**Purple Knight** est un outil d'audit de sécurité développé par Semperis. Contrairement à un simple scanner de vulnérabilités, il se concentre sur les **Indicateurs d'Exposition (IoE)** et les **Indicateurs de Compromission (IoC)** spécifiques à l'Active Directory.

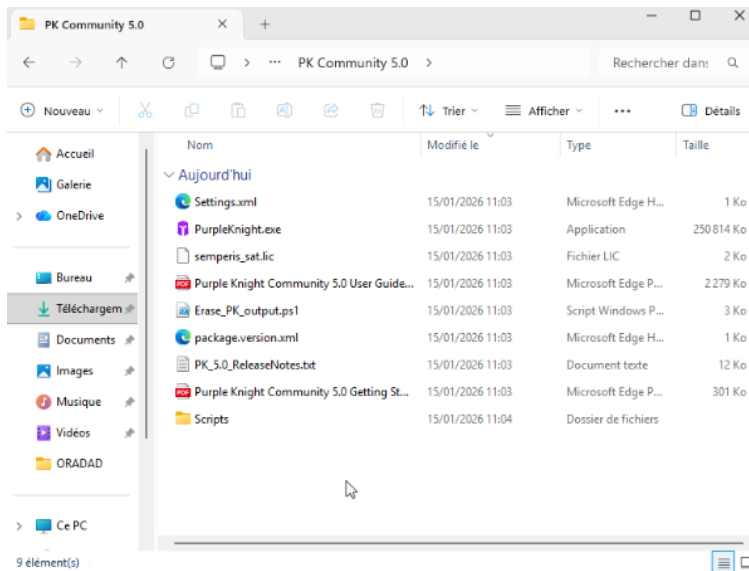


The screenshot shows the 'request-form/' page of the Purple Knight tool. The page has a dark theme with purple accents. At the top, there's a navigation bar with links for 'Blog', 'Email us', 'Support', 'Slack', and 'English'. A 'Download Now' button is highlighted in yellow. Below the navigation bar, the 'purple knight' logo is displayed, along with the text 'powered by semperis'. The main heading is 'Protect your Active Directory Vulnerabilities'. Below this, the version 'Purple Knight 5.0 Community' is noted. The form itself is divided into two main sections. The left section contains input fields for 'First Name', 'Last Name', 'Business Email', 'Company', 'Company Size' (a dropdown menu), 'Industry' (a dropdown menu), and 'Country' (a dropdown menu). The right section features a 'Join the Purple Knight community' button with a 'Slack access' link below it. At the bottom right, there's a small 'Active Windows' notification.

## 2. Phase de Lancement et Configuration

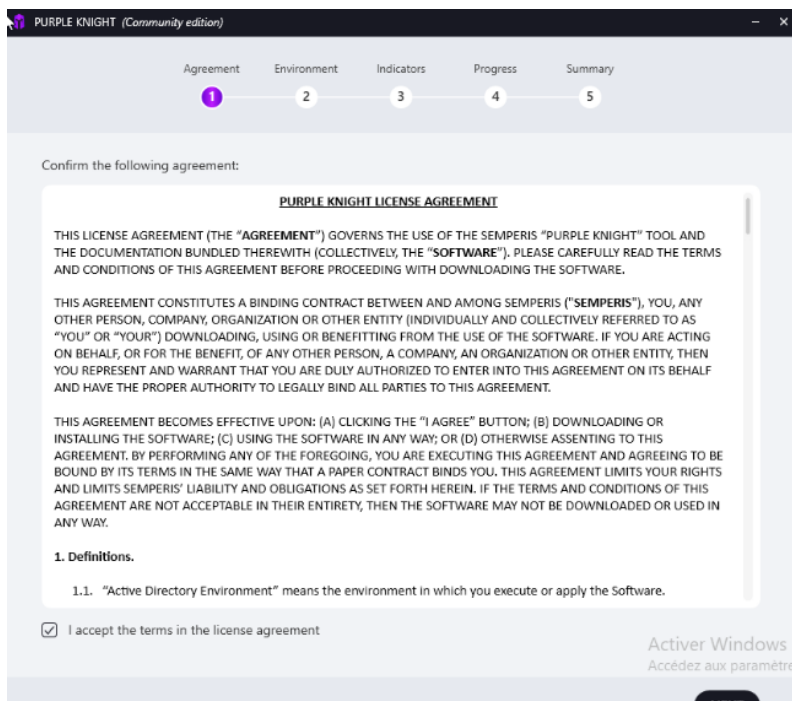
### A. Exécution du programme

- **Action** : Lancement de PurpleKnight.exe.
- **Commentaire** : L'outil s'exécute sans installation. Il nécessite d'être lancé depuis une machine membre du domaine avec un compte disposant de droits de lecture sur l'ensemble de l'annuaire (généralement un administrateur du domaine pour un scan complet).



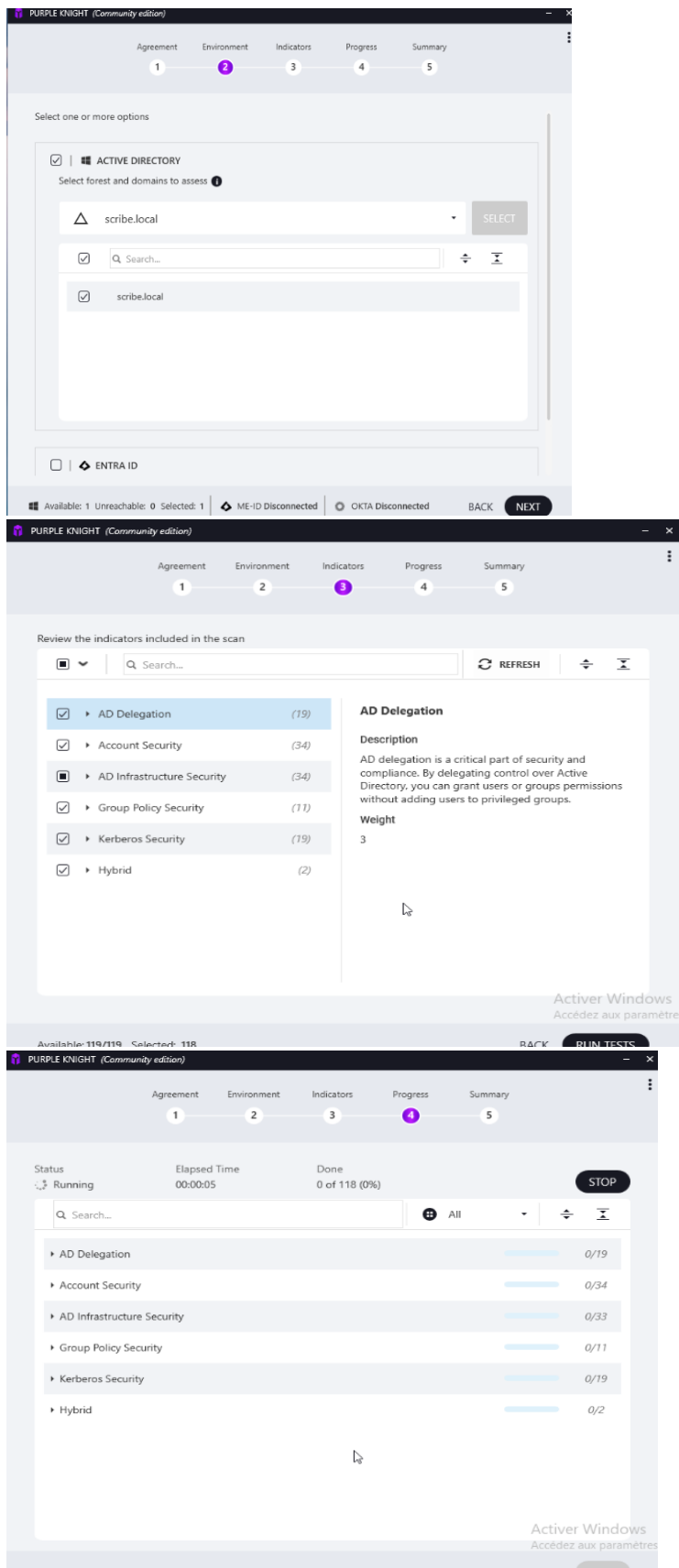
## B. Acceptation des termes et conditions

- **Action** : Validation de la licence "Community Edition".
- **Commentaire** : Cette version est gratuite pour les audits ponctuels et permet d'accéder à plus de 100 indicateurs de sécurité mis à jour régulièrement.



## C. Sélection du périmètre

- **Action** : Choix du domaine scribe.local.
- **Commentaire** : L'outil détecte automatiquement la forêt et le domaine actuels. On sélectionne ici l'Active Directory comme cible principale.



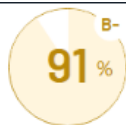
### 3. Analyse du Score Global

- **Score obtenu : 91% (Grade B-).**
- **Explication :** Ce score est une moyenne pondérée. Bien que le chiffre semble élevé, la présence de vulnérabilités dans la catégorie "Critical" (Sévérité Critique) signifie que le domaine peut être compromis malgré une bonne note globale.



#### Active Directory

Forest: scribe.local  
IOEs found: 14  
Run by: SCRIBE\Administrator



#### ACTIVE DIRECTORY

Forest: scribe.local  
No. of Domains: 1  
Duration: 00:01:02  
Run by: SCRIBE\Administr...

#### Indicators

|               |     |
|---------------|-----|
| Evaluated     | 113 |
| Not selected  | 1   |
| IOEs found    | 14  |
| Passed        | 99  |
| Failed to run | 2   |
| Not Relevant  | 3   |
| Canceled      | 0   |

### CRITICAL IOEs FOUND

#### SMB Signing is not required on Domain Controllers

This indicator looks for domain controllers where SMB signing is not required.

[Read More](#)

#### SMBv1 is enabled on Domain Controllers

This indicator looks for domain controllers where SMBv1 protocol is enabled.

[Read More](#)

## ADDITIONAL IOEs FOUND

| NAME                                                                   | PLATFORM | SEVERITY LEVEL                                                            | ACTION                    |
|------------------------------------------------------------------------|----------|---------------------------------------------------------------------------|---------------------------|
| • LDAP signing is not required on Domain Controllers                   | AD       | High <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |
| • Write access to RBCD on DC                                           | AD       | High <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |
| • Write access to RBCD on krbtgt account                               | AD       | High <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |
| • Built-in domain Administrator account used within the last two weeks | AD       | Medium <div><div></div><div></div><div></div><div></div><div></div></div> | <a href="#">Read More</a> |
| • gMSA not in use                                                      | AD       | Medium <div><div></div><div></div><div></div><div></div><div></div></div> | <a href="#">Read More</a> |
| • Smart card password rotation disabled                                | AD       | Medium <div><div></div><div></div><div></div><div></div><div></div></div> | <a href="#">Read More</a> |
| • Domains with obsolete functional levels                              | AD       | Low <div><div></div><div></div><div></div><div></div><div></div></div>    | <a href="#">Read More</a> |
| • Recent privileged account creation activity                          | AD       | Low <div><div></div><div></div><div></div><div></div><div></div></div>    | <a href="#">Read More</a> |
| • SYSVOL Executable Changes                                            | AD       | Low <div><div></div><div></div><div></div><div></div><div></div></div>    | <a href="#">Read More</a> |
| • Unprivileged users can add computer accounts to the domain           | AD       | Low <div><div></div><div></div><div></div><div></div><div></div></div>    | <a href="#">Read More</a> |
| • AD objects created within the last 10 days                           | AD       | Info <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |
| • Users with Password Never Expires flag set                           | AD       | Info <div><div></div><div></div><div></div><div></div><div></div></div>   | <a href="#">Read More</a> |

## Analyse des Indicateurs d'Exposition (IoE)

Mon audit Purple Knight met en évidence plusieurs vulnérabilités structurelles, confirmant mes observations précédentes sur les failles de sécurité de l'Active Directory :

### Risques de Sévérité Haute (Critiques)

- **Signature LDAP non requise sur les DC (+ High) :** Le contrôleur de domaine n'impose pas la signature des flux LDAP. Cette vulnérabilité est majeure car elle permet à un attaquant positionné sur le réseau d'effectuer une attaque de type "Man-in-the-Middle" pour intercepter des informations d'authentification ou modifier la base de données de l'annuaire.
- **Accès en écriture à la RBCD sur le DC et le compte krbtgt (+ High) :** Des permissions d'écriture ont été détectées sur la délégation Kerberos basée sur les ressources (RBCD) pour ces deux entités critiques. Un attaquant pourrait exploiter ce levier pour compromettre totalement le domaine ou usurper l'identité du compte krbtgt, pilier central de la sécurité Kerberos.

### Risques de Sévérité Moyenne

- **Utilisation du compte Administrateur intégré (+ Medium) :** Le compte "Administrateur" natif du domaine a été actif récemment. L'audit souligne ici un manque d'hygiène : ce compte devrait être désactivé pour limiter les risques de "Brute Force" et de compromission globale, au profit de comptes nominatifs.
- **gMSA non utilisé (+ Medium) :** Les comptes de service gérés par le groupe (group Managed Service Accounts) ne sont pas déployés. Cela signifie que mes services utilisent probablement des mots de passe statiques, plus vulnérables aux attaques par dictionnaire ou par vol de hash.

- **Rotation des mots de passe par carte à puce désactivée (+ Medium)** : Cette option de sécurité n'est pas activée, ce qui affaiblit le durcissement de l'authentification forte au sein de mon domaine lab.local.

### Risques de Sévérité Faible & Infos

- **Niveaux fonctionnels obsolètes (+ Low)** : Mon domaine utilise un niveau fonctionnel ancien. C'est la "dette technique" liée à Samba4 que j'avais déjà notée sur mon lab UCS, empêchant l'usage des protections Kerberos les plus récentes.
- **Création de comptes ordinateurs par des non-privilegiés (+ Low)** : Des utilisateurs standards ont toujours la capacité d'ajouter des machines au domaine. Comme je l'ai vu avec PingCastle, c'est une règle de base qu'il me faut corriger pour limiter l'introduction de machines hostiles.
- **Usage de mots de passe n'expirant jamais (Info)** : Certains utilisateurs possèdent ce flag. En cas de vol d'identifiant, l'absence d'expiration offre une persistance illimitée à l'intrus.

## 4. Analyse des Vulnérabilités Critiques (Les "Critiques")

**SECURITY INDICATOR**  
**gMSA not in use**

IOE Found

94%<sup>B</sup>

SEVERITY

Medium

WEIGHT

4

**Security Frameworks**  
 MITRE ATT&CK
 

- Credential Access

**Description**  
 This indicator checks if there are enabled group Managed Service Account (gMSA) objects in the domain.

**Likelihood of Compromise**  
 The group Managed Service Account (gMSA) feature in Windows Server 2016 allows automatic rotation of passwords for service accounts, making them much more difficult for attackers to compromise. The feature should be used whenever possible for service accounts.

**References**  
[Get started with Group Managed Service Accounts](#)

**Result**  
 Found 1 domains with no gMSA objects enabled.
 

| DomainName   | Ignored |
|--------------|---------|
| scribe.local | False   |

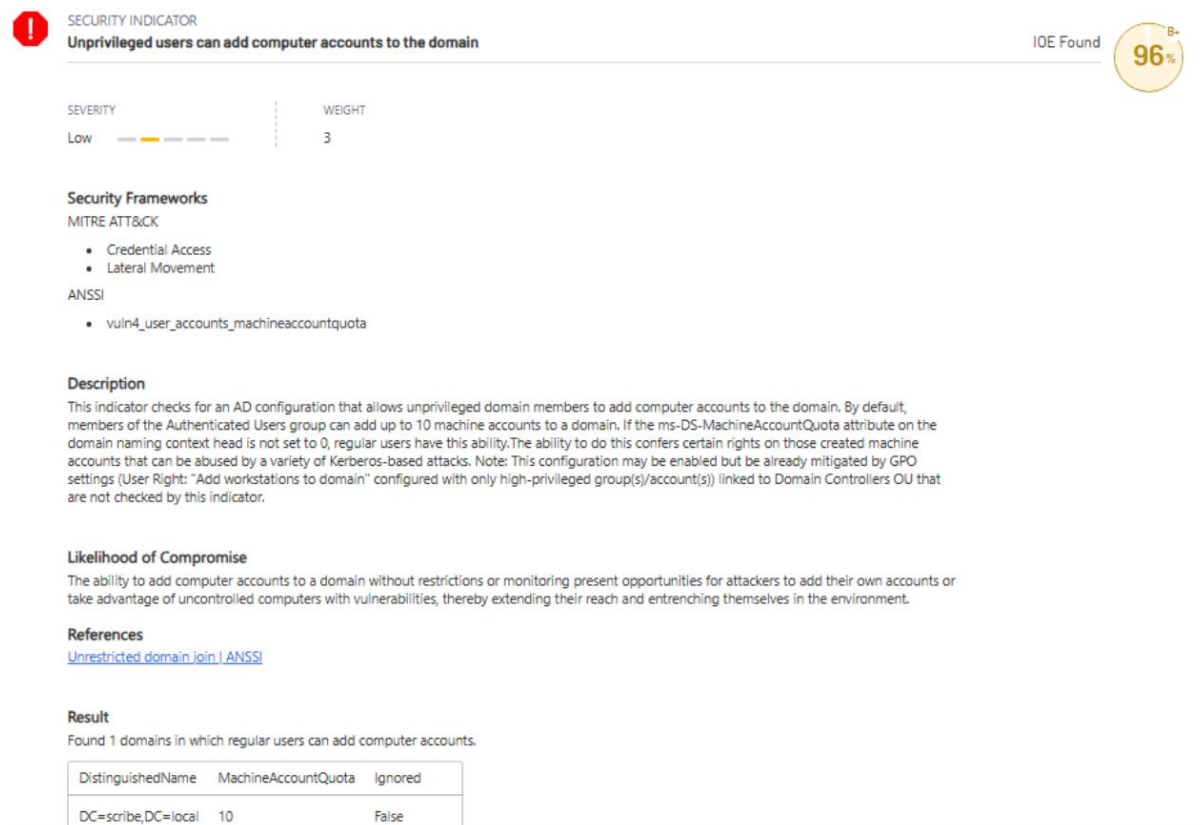
 Showing 1 of 1

**Remediation Steps**  
 Group Managed Service Accounts should be used to protect service accounts. See description for more information.

### gMSA not in use (Sévérité Moyenne)

Cet indicateur vérifie s'il existe des objets de type "Group Managed Service Account" (gMSA) actifs dans le domaine.

- **Explication (Cause) :** Mon infrastructure utilise des comptes de service classiques pour le fonctionnement des applications réseau. Purple Knight confirme qu'aucun objet gMSA n'est activé dans mon domaine scribe.local. Ces comptes standards m'imposent une gestion manuelle des mots de passe, ce qui mène souvent à l'utilisation de secrets statiques ou sans expiration, contrairement aux bonnes pratiques de sécurité.
- **Conséquence (Risque) :** Cette absence de gMSA augmente la vulnérabilité de mes comptes de service aux compromissions de type "Credential Access" selon le framework MITRE ATT&CK. Contrairement aux comptes classiques, la fonctionnalité gMSA (disponible depuis Windows Server 2016) assure une rotation automatique et complexe des mots de passe gérée directement par l'Active Directory, ce qui rendrait le vol d'identifiants ou le craquage par force brute extrêmement difficiles pour un attaquant.



## Unprivileged users can add computer accounts to the domain (Sévérité Faible)

Cet indicateur vérifie la configuration Active Directory qui autorise les membres non privilégiés du domaine à ajouter des comptes d'ordinateurs à l'annuaire.

- **Explication (Cause) :** Par défaut, les membres du groupe "Utilisateurs authentifiés" peuvent joindre jusqu'à 10 machines au domaine. Mon audit confirme que l'attribut ms-DS-MachineAccountQuota est toujours défini sur sa valeur par défaut de **10** sur mon contrôleur de domaine DC=scribe,DC=local. Cette capacité est souvent méconnue mais activée par défaut dans la plupart des environnements Windows et Samba4.

- **Conséquence (Risque) :** Selon les frameworks MITRE ATT&CK et l'ANSSI (vuln4), cette faille facilite l'accès aux identifiants et le mouvement latéral. Elle offre une opportunité à un attaquant d'introduire ses propres machines non contrôlées ou vulnérables dans mon réseau, étendant ainsi sa portée et consolidant sa persistance au sein de l'environnement sans restriction ni surveillance.



SECURITY INDICATOR

Built-in domain Administrator account used within the last two weeks

IOE Found

B-

91%

SEVERITY

Medium

WEIGHT

5

Security Frameworks

MITRE ATT&CK

- Credential Access

MITRE D3FEND

- Detect - Credential Compromise Scope Analysis
- Harden - Strong Password Policy

Description

The Domain Administrator account should only be used for initial build activities and, when necessary, disaster recovery. This indicator checks to see if the lastLogonTimestamp for the built-in Domain Administrator account has been updated within the last two weeks. If so, it could indicate that the user has been compromised.

Likelihood of Compromise

If best practices are followed and domain Admin is not used, this would indicate a compromise. Ensure any logins to the built-in Domain Administrator account are legitimate and accounted for. If not accounted for, a breach is likely and should be investigated.

Result

Found 1 domains in which the built-in administrator was used recently.

| DistinguishedName                            | EventTimestamp      | Ignored |
|----------------------------------------------|---------------------|---------|
| CN=Administrator,CN=Users,DC=scribe,DC=local | 21/01/2026 10:36:37 | False   |

Showing 1 of 1

Remediation Steps

Ensure that the built-in domain Administrator account is not used regularly and has a complex password known only to highly privileged admins.

## Built-in domain Administrator account used within the last two weeks (Sévérité Moyenne)

Cet indicateur surveille l'horodatage de la dernière connexion (lastLogonTimestamp) pour le compte administrateur natif du domaine.

- **Explication (Cause) :** Purple Knight a détecté une activité récente sur le compte CN=Administrator,CN=Users,DC=scribe,DC=local en date du **21/01/2026**. Par défaut, ce compte ne devrait être utilisé que pour les activités de construction initiale de l'annuaire ou pour des cas de récupération après sinistre. Une utilisation régulière indique que je ne privilégie pas encore des comptes administratifs nominatifs pour mes tâches quotidiennes.
- **Conséquence (Risque) :** Si les meilleures pratiques ne sont pas suivies et que ce compte est utilisé inutilement, cela augmente considérablement la probabilité de compromission (Credential Access). Comme ce compte est une cible de choix connue de tous les attaquants, toute connexion non justifiée doit être traitée comme une brèche potentielle et faire l'objet d'une enquête approfondie.





SEVERITY  
Info

WEIGHT  
1

#### Security Frameworks

##### MITRE ATT&CK

- Lateral Movement
- Persistence

##### MITRE D3FEND

- Detect - Domain Account Monitoring

#### Description

This indicator looks for any AD objects that were created within the last 10 days. It is meant to be used for threat hunting, post-breach investigation or compliance validation.

#### Likelihood of Compromise

In some environments, object creation happens consistently; however, recently added accounts should be reviewed to ensure they are legitimate.

#### References

[Audit User Account Management | Microsoft Learn](#)

#### Result

Found 283 objects that were created in the last 10 days.

| DistinguishedName                                                                                           | ObjectName                                                   | ObjectClass            | EventTimestamp      |
|-------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------|------------------------|---------------------|
| CN=ipsecNFA(7238523E-70FA-11D1-864C-14A300000000),CN=IP Security,CN=System,DC=scribe,DC=local               | ipsecNFA(7238523E-70FA-11D1-864C-14A300000000)               | ipsecNFA               | 21/01/2026 10:36:27 |
| CN=ipsecNegotiationPolicy(593198DF-5EE3-11D2-ACE8-006080ECCA17),CN=IP Security,CN=System,DC=scribe,DC=local | ipsecNegotiationPolicy(593198DF-5EE3-11D2-ACE8-006080ECCA17) | ipsecNegotiationPolicy | 21/01/2026 10:36:27 |
| CN=ethers,CN=ypServ30,CN=RpcServices,CN=System,DC=scribe,DC=local                                           | ethers                                                       | container              | 21/01/2026 10:36:29 |
| CN=netgroup,CN=ypServ30,CN=RpcServices,CN=System,DC=scribe,DC=local                                         | netgroup                                                     | container              | 21/01/2026 10:36:29 |

## AD objects created within the last 10 days (Sévérité Info)

Cet indicateur recherche tous les objets Active Directory qui ont été créés au cours des 10 derniers jours. Il s'agit d'un outil essentiel pour la recherche de menaces (threat hunting), l'investigation post-brèche ou la validation de la conformité.

- **Explication (Cause)** : Purple Knight a trouvé **283 objets** créés récemment dans mon annuaire, avec des horodatages correspondant au **21/01/2026**. Dans mon cas, cela correspond à l'étape finale de l'instanciation de mon serveur Scribe AD, où le système génère automatiquement toute la structure de l'annuaire, y compris les conteneurs système comme Program Data, les politiques de négociation IPsec, et le compte d'ordinateur du contrôleur de domaine ADDC.
- **Conséquence (Risque)** : Bien que la création d'objets soit un processus normal, une augmentation soudaine et inexpliquée peut signaler une activité malveillante de type "Lateral Movement" ou "Persistence" (cadre MITRE ATT&CK). Un attaquant pourrait créer des comptes ou des groupes pour maintenir son accès. Dans mon environnement de lab, ces objets sont légitimes car ils sont liés à l'installation neuve, mais je dois rester vigilant si de nouveaux objets apparaissent sans action de ma part.



## SECURITY INDICATOR

### Recent privileged account creation activity

IOE Found

92%

#### SEVERITY

Low

#### WEIGHT

3

#### Security Frameworks

MITRE ATT&CK

- Persistence

MITRE D3FEND

- Detect - Domain Account Monitoring

#### Description

This indicator looks for any users or groups that were created within the last month. Privileged accounts and groups are defined by having their adminCount attribute set to 1.

#### Likelihood of Compromise

In most environments, creation of privileged accounts and groups is tightly controlled and audited. This indicator provides a fast method to create a list of new privileged accounts (where adminCount = 1) for investigation and review.

#### References

[audit-user-account-management of Microsoft](#)

#### Result

Found 2 objects that were created in the last 30 days and are members of a privileged group.

| DistinguishedName                            | SamAccountName | EventTimestamp      | Ignored |
|----------------------------------------------|----------------|---------------------|---------|
| CN=Administrator,CN=Users,DC=scribe,DC=local | Administrator  | 21/01/2026 10:36:27 | False   |
| CN=krbtgt,CN=Users,DC=scribe,DC=local        | krbtgt         | 21/01/2026 10:36:28 | False   |

Showing 2 of 2

#### Remediation Steps

Review the list and verify that all privileged accounts and groups that were recently created are valid. Ideally, all privileged account creation goes through an approval-based workflow and gets periodic attestation.

## Recent privileged account creation activity (Sévérité Faible)

Cet indicateur identifie les utilisateurs ou groupes créés au cours du dernier mois dont l'attribut adminCount est défini sur 1, ce qui les marque comme étant hautement privilégiés.

- **Explication (Cause)** : Purple Knight a détecté la création de **2 objets privilégiés** au cours des 30 derniers jours, tous deux horodatés au **21/01/2026**. Il s'agit des comptes fondamentaux Administrator et krbtgt, créés automatiquement lors de la phase d'instanciation de mon annuaire Samba4 sur le serveur Scribe. Dans la plupart des environnements établis, la création de tels comptes est un processus strictement contrôlé et audité.
- **Conséquence (Risque)** : Bien que ces créations soient légitimes dans mon contexte de lab, une activité inattendue dans cette catégorie peut signaler une tentative de "Persistence" par un attaquant (cadre MITRE ATT&CK). En créant de nouveaux comptes privilégiés, un intrus s'assure de conserver un contrôle total sur le domaine, même si son point d'entrée initial est découvert. Dans un environnement de production, l'apparition de nouveaux comptes avec un adminCount à 1 sans ticket de changement associé doit déclencher une investigation immédiate.



## SEVERITY

Info

## WEIGHT

1

## Security Frameworks

## MITRE ATT&amp;CK

- Credential Access

## MITRE D3FEND

- Harden - Strong Password Policy

## ANSSI

- vuln2\_dont\_expire

## Description

This indicator identifies user accounts where the Password Never Expires flag is set. These accounts can be targets for brute force password attacks, given that their passwords may not be strong when they were set. These accounts also tend to be service accounts with privileged access to applications and services, including Kerberos-based services.

## Likelihood of Compromise

Passwords that never expire may be weak and easier to crack. These credentials can provide attackers opportunities for moving laterally or escalating privileges.

## References

[NIST SP 800-63-3](#)

[Accounts with never-expiring passwords \(ANSSI\)](#)

## Result

Found 4 users with password never expires.

| DistinguishedName                                       | SamAccountName           | PasswordLastSet     | ServicePrincipalName | Ignored |
|---------------------------------------------------------|--------------------------|---------------------|----------------------|---------|
| CN=eole-workstation-manager,CN=Users,DC=scribe,DC=local | eole-workstation-manager | 21/01/2026 09:43:43 |                      | False   |
| CN=eole-synchro,CN=Users,DC=scribe,DC=local             | eole-synchro             | 21/01/2026 09:42:06 |                      | False   |
| CN=eole-workstation-reader,CN=Users,DC=scribe,DC=local  | eole-workstation-reader  | 21/01/2026 09:43:47 |                      | False   |
| CN=eole-sasl,CN=Users,DC=scribe,DC=local                | eole-sasl                | 21/01/2026 09:43:59 |                      | False   |

## Users with Password Never Expires flag set (Sévérité Info)

Cet indicateur identifie les comptes utilisateurs pour lesquels l'option "Le mot de passe n'expire jamais" est activée.

- **Explication (Cause)** : Purple Knight a détecté **4 comptes** avec ce flag activé, tous horodatés au **21/01/2026**. Il s'agit de comptes de service techniques créés lors de l'instanciation de mon serveur Scribe AD : eole-workstation-manager, eole-synchro, eole-workstation-reader et eole-sasl. Ces comptes ont souvent besoin de cette configuration pour éviter que des services réseau ne s'arrêtent brutalement suite à un changement de mot de passe automatique.
- **Conséquence (Risque)** : Selon les référentiels de l'ANSSI (vuln2) et du NIST, ces comptes sont des cibles privilégiées pour des attaques par force brute. Si les mots de passe n'ont pas été définis avec une complexité suffisante dès le départ, un attaquant peut prendre le temps nécessaire pour les casser. Une fois compromis, ces identifiants offrent une opportunité idéale pour se déplacer latéralement ou augmenter ses privilèges au sein du domaine scribe.local, car l'accès reste valide indéfiniment.

SECURITY INDICATOR

Domains with obsolete functional levels

IOE Found

5+

96%

SEVERITY

Low

WEIGHT

3

Security Frameworks

MITRE ATT&CK

- Reconnaissance

MITRE D3FEND

- Harden - Software Update

ANSSI

- vuln1\_functional\_level
- vuln3\_functional\_level
- vuln4\_functional\_level

Description

This indicator looks for AD domains that have a domain functional level set to Windows Server 2012 R2 or lower. These lower functional levels mean that newer security features available in AD cannot be leveraged. If the OS version of your domain controllers supports it, you should update to a newer domain functional level to take full advantage of security advancements in AD.

Likelihood of Compromise

While domain functional level is not a weakness in and of itself, an attacker with knowledge of functional levels can adjust their approach to take advantage of lack of security features in AD.

References

[Forest and Domain Functional Levels](#)  
[Insufficient forest and domains functional levels \(ANSSI\)](#)

Result

Found 1 domains with low domain functionality level.

| FunctionalLevel | DomainName   | FunctionalLevelInfo | Ignored |
|-----------------|--------------|---------------------|---------|
| 4               | scribe.local | 2008 R2             | False   |

Showing 1 of 1

## Domains with obsolete functional levels (Sévérité Faible)

Cet indicateur recherche les domaines Active Directory dont le niveau fonctionnel est défini sur Windows Server 2012 R2 ou une version antérieure.

- Explication (Cause) :** Mon domaine est actuellement configuré avec un niveau fonctionnel **4**, ce qui correspond à **Windows Server 2008 R2**. Comme je l'avais noté lors de mes tests sur UCS et Samba4, il s'agit d'une limitation technique de la version émulée de Samba qui ne permet pas encore d'atteindre des niveaux fonctionnels plus récents nativement.
- Conséquence (Risque) :** Selon les préconisations de l'ANSSI (vuln1, vuln3, vuln4), l'utilisation de niveaux fonctionnels obsolètes m'empêche de bénéficier des dernières avancées en matière de sécurité Active Directory. Un attaquant ayant connaissance de ces limites peut ajuster ses méthodes pour exploiter l'absence de fonctionnalités modernes, telles que les silos d'authentification ou les protections Kerberos renforcées, augmentant ainsi les chances de succès d'une attaque par reconnaissance ou mouvement latéral.

SECURITY INDICATOR

Smart card password rotation disabled

IOE Found 

0%

SEVERITY

Medium

WEIGHT

4

Security Frameworks

MITRE ATT&CK

- Lateral Movement

ANSSI

- vuln4\_smartcard\_expire\_passwords

Description

This indicator checks whether the msDS-ExpirePasswordsOnSmartCardOnlyAccounts attribute, which determines if smart card-only accounts must follow regular password rotation schedules, is disabled.

Likelihood of Compromise

The msDS-ExpirePasswordsOnSmartCardOnlyAccounts attribute is a security configuration that determines if smart card-only accounts must follow regular password rotation schedules. When enabled, it ensures these specialized accounts comply with the domain's password policy. This security feature is available in domains operating at Windows Server 2016 functional level or higher. While not immediately indicative of an attack, when disabled, smart card-only accounts can maintain the same password indefinitely, potentially creating a security vulnerability that attackers can exploit for persistent access and lateral movement.

References

[Attribute msDS-ExpirePasswordsOnSmartCardOnlyAccounts](#)  
[Missing password expiration for smart card users | ANSSI](#)

Result

Found 1 domains with msDS-ExpirePasswordsOnSmartCardOnlyAccounts disabled.

| DistinguishedName  | Status                                 | Ignored |
|--------------------|----------------------------------------|---------|
| DC=scribe,DC=local | Smart card password rotation disabled. | False   |

Showing 1 of 1

Remediation Steps

To remediate this security issue, enable the msDS-ExpirePasswordsOnSmartCardOnlyAccounts attribute by opening ADSIEdit.msc with an account that has domain administrative privileges. Connect to the Configuration naming context, navigate to the domain configuration object, right-click on the domain object, and select "Properties". Go to the

## Smart card password rotation disabled (Sévérité Moyenne)

Cet indicateur vérifie si l'attribut msDS-ExpirePasswordsOnSmartCardOnlyAccounts est désactivé, ce qui détermine si les comptes utilisant uniquement une carte à puce doivent suivre les cycles réguliers de rotation des mots de passe.

- Explication (Cause) :** Purple Knight a détecté que cette configuration de sécurité est désactivée sur mon domaine DC=scribe,DC=local. Bien que cette fonctionnalité nécessite normalement un niveau fonctionnel Windows Server 2016 ou supérieur pour être pleinement exploitée, son état actuel indique que mes politiques de sécurité ne forcent pas le renouvellement des secrets pour les méthodes d'authentification forte.
- Conséquence (Risque) :** Selon les référentiels de l'ANSSI (vuln4), lorsque cette option est désactivée, les comptes à carte à puce peuvent conserver le même mot de passe indéfiniment. Cela crée une vulnérabilité de sécurité qu'un attaquant peut exploiter pour maintenir un accès persistant ou effectuer des mouvements latéraux au sein du réseau, car l'absence d'expiration réduit les chances de détecter un compte dont les identifiants auraient été compromis.

LDAP signing is not required on Domain Controllers

IOE Found82%

SEVERITY

High

WEIGHT

7

Security Frameworks

MITRE ATT&CK

- Privilege Escalation
- Credential Access

Description

This indicator checks for domain controllers where LDAP signing is not required.

Likelihood of Compromise

Unsigned network traffic is exposed to MITM attacks, where attackers alter packets and forward them to the LDAP server, causing the server to make decisions based on forged requests from the LDAP client.

References

[Domain controller LDAP server signing requirements - Windows 10 | Microsoft Learn](#)  
[Network security LDAP client signing requirements - Windows 10 | Microsoft Learn](#)

Result

Found 1 DCs that do not require LDAP Signing.

| DistinguishedName                                | HostName          | State                     | Ignored |
|--------------------------------------------------|-------------------|---------------------------|---------|
| CN=ADDC,OU=Domain Controllers,DC=scribe,DC=local | addc.scribe.local | Ldap Signing Not Required | False   |

Showing 1 of 1

Remediation Steps

To remediate follow the steps below:  
If the steps are not followed in order, disruption to Active Directory may occur.

1. Configure clients to request LDAP signing. Group policy: Network security:LDAP client signing requirements. select Negotiate signing.
2. When all clients request signing, configure domain controllers to require LDAP signing. Group policy: Domain Controller:LDAP server signing requirements. select Require signing.
3. Configure clients to require LDAP signing. Group policy: Network security:LDAP client signing requirements. select Require signing.
4. For full details on the process please see the reference articles.

## LDAP signing is not required on Domain Controllers (S  v  rit   Haute)

Cet indicateur v  rifie si mes contr  leurs de domaine imposent la signature num  rique pour les communications LDAP.

- **Explication (Cause) :** Mon audit confirme que pour le contr  leur de domaine addc.scribe.local, l'  tat de la signature LDAP est d  fini sur "**Ldap Signing Not Required**". Cela signifie que le serveur accepte des connexions LDAP simples (en clair) sans exiger de preuve d'int  grit   cryptographique pour chaque paquet   chang  .
- **Cons  quence (Risque) :** Selon le framework MITRE ATT&CK, cette absence de signature expose directement mon annuaire    des attaques de type "**Privilege Escalation**" et "**Credential Access**". Un attaquant capable d'intercepter le trafic r  seau peut mener une attaque de l'homme du milieu (MiTM), modifier les paquets LDAP    la vol  e pour forger des requ  tes, ou voler des identifiants de connexion, permettant ainsi une prise de contr  le non autoris  e du domaine.



#### SECURITY INDICATOR

#### SMB Signing is not required on Domain Controllers

IOE Found

73%

#### SEVERITY

Critical

#### WEIGHT

8

#### Security Frameworks

##### MITRE ATT&CK

- Privilege Escalation
- Credential Access

#### Description

This indicator looks for domain controllers where SMB signing is not required.

#### Likelihood of Compromise

Unsigned network traffic is susceptible to attacks abusing the NTLM challenge-response protocol. A common example of such attacks is SMB Relay, where an attacker is positioned between the client and the server in order to capture data packets transmitted between the two, thus gaining unauthorized access to the server or other servers on the network.

#### References

[Configure SMB Signing with Confidence](#)

#### Result

Found 1 DCs that do not require SMB Signing.

| DistinguishedName                                | HostName          | State                       | Ignored |
|--------------------------------------------------|-------------------|-----------------------------|---------|
| CN=ADDC,OU=Domain Controllers,DC=scribe,DC=local | addc.scribe.local | SMB Signing is not required | False   |

Showing 1 of 1

#### Remediation Steps

The following Group Policies need to be enabled in order to enforce SMB Signing on DCs:

- Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Microsoft network server: Digitally sign communications (always): This policy controls whether the server providing SMB required signing. It determines if SMB signing will have to be negotiated prior to further communication.
- Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Microsoft network server: Digitally sign communications (if client agrees): This policy determines if SMB server will negotiate SMB signing with clients that request it.

## SMB Signing is not required on Domain Controllers (Sévérité Critique)

Cet indicateur recherche les contrôleurs de domaine où la signature SMB n'est pas imposée pour les communications réseau.

- Explication (Cause) :** Mon audit révèle que sur le contrôleur de domaine addc.scribe.local, l'état de la signature est défini sur "**SMB Signing is not required**". Cela signifie que le serveur n'exige pas de signature numérique pour les échanges de fichiers et de données via le protocole SMB, laissant les sessions sans protection d'intégrité.
- Conséquence (Risque) :** Selon le framework MITRE ATT&CK, ce trafic réseau non signé est vulnérable aux attaques par relais NTLM (SMB Relay). Un attaquant positionné entre un client et mon serveur Scribe peut capturer les paquets de données et les relayer pour obtenir un accès non autorisé au serveur ou à d'autres machines du réseau, ce qui peut mener à une escalade de privilèges ou à un vol d'identifiants (Credential Access).



## SECURITY INDICATOR SMBv1 is enabled on Domain Controllers

IOE Found

73%

### SEVERITY

Critical

### WEIGHT

8

### Security Frameworks

MITRE ATT&CK

- Privilege Escalation
- Credential Access

### Description

This indicator looks for domain controllers where SMBv1 protocol is enabled.

### Likelihood of Compromise

SMBv1 is an old protocol, considered unsafe and susceptible to all kinds of attacks. It was publicly deprecated by Microsoft in 2014.

### References

[Configure SMB Signing with Confidence](#)

### Result

Found 1 DCs with SMBv1 Enabled.

| DistinguishedName                                | HostName          | State            | Ignored |
|--------------------------------------------------|-------------------|------------------|---------|
| CN=ADDC,OU=Domain Controllers,DC=scribe,DC=local | addc.scribe.local | SMBv1 is enabled | False   |

Showing 1 of 1

### Remediation Steps

Microsoft recommends to disable SMBv1 whenever possible on both client and server side. Do note, before disabling SMBv1 and to avoid additional errors, make sure best practices are followed regarding the usage of deprecated OS (Windows 2000, 2003, XP, CE), network printers using SMBv1 scan2shares functionalities, or software accessing Windows share with a custom implementation relying on SMBv1.

## SMBv1 is enabled on Domain Controllers (Sévérité Critique)

Cet indicateur vérifie si le protocole obsolète SMBv1 est toujours activé sur mes contrôleurs de domaine.

- **Explication (Cause)** : Mon audit révèle que sur le contrôleur de domaine addc.scribe.local, l'état est confirmé à **"SMBv1 is enabled"**. SMBv1 est un protocole extrêmement ancien, considéré comme non sécurisé et vulnérable à de nombreuses attaques ; il a d'ailleurs été publiquement déprécié par Microsoft dès 2014.
- **Conséquence (Risque)** : Selon le framework MITRE ATT&CK, le maintien de SMBv1 expose mon annuaire à des risques d'escalade de privilèges et de vol d'identifiants (Credential Access). Sa présence est particulièrement dangereuse car elle facilite les attaques par relais et l'exploitation de failles critiques de type exécution de code à distance (comme ce fut le cas avec l'attaque WannaCry).



! SECURITY INDICATOR

SYSVOL Executable Changes

IOE Found 92%

SEVERITY

Low

WEIGHT

3

Security Frameworks

MITRE ATT&CK

- Privilege Escalation
- Execution
- Persistence

MITRE D3FEND

- Detect - File Analysis

Description

This indicator looks for modifications to executable files within SYSVOL. It only examines files and executables that have read access to them.

Likelihood of Compromise

Changes to the executable files within SYSVOL should be accounted for by the administrators. If the change can not be accounted for, investigate the change looking for potential weakening of security posture and why the change was made.

Result

Found 2 SYSVOL executables that have been recently modified.

| FileName          | FileDirectory                                                                                              | GPODisplayName | EventTimestamp      | Ignored |
|-------------------|------------------------------------------------------------------------------------------------------------|----------------|---------------------|---------|
| installMinion.ps1 | \\scribe.local\SYSVOL\scribe.local\Policies\{71C9AFB8-D7AA-49A4-8F04-BABD48BC48BA}\Machine\Scripts\Startup | eole_script    | 21/01/2026 10:43:28 | False   |
| ps.ps1            | \\scribe.local\SYSVOL\scribe.local\Policies\{71C9AFB8-D7AA-49A4-8F04-BABD48BC48BA}\User\Scripts\Logon      | eole_script    | 21/01/2026 10:43:28 | False   |

Showing 2 of 2

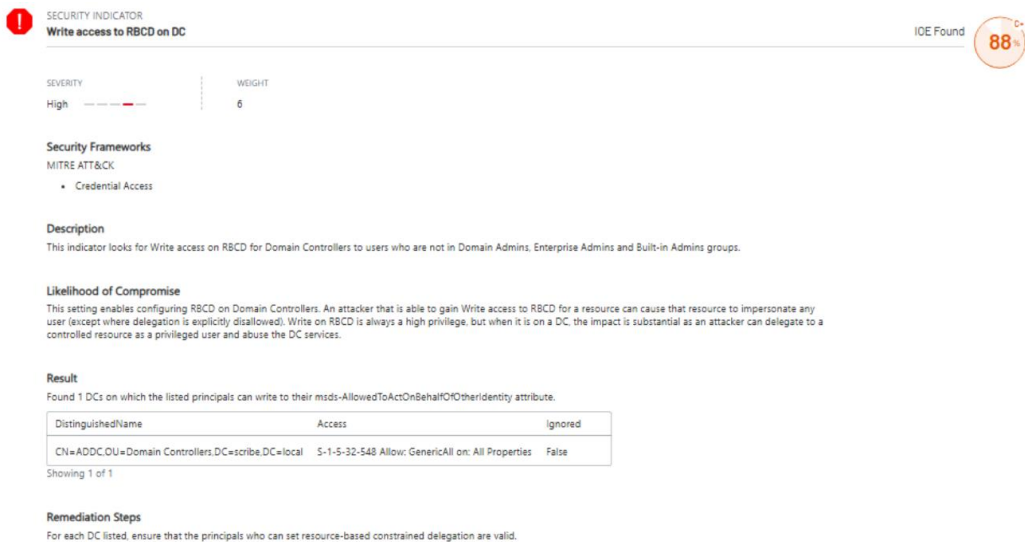
Remediation Steps

Ensure all recently created/modified executables are safe.

## SYSVOL Executable Changes (Sévérité Faible)

Cet indicateur recherche toute modification apportée aux fichiers exécutables ou aux scripts stockés au sein du répertoire SYSVOL, auquel tous les utilisateurs ont accès en lecture.

- **Explication (Cause)** : Purple Knight a détecté **2 exécutables SYSVOL** ayant été modifiés récemment, le **21/01/2026**. Il s'agit des scripts PowerShell installMinion.ps1 (script de démarrage machine) et ps.ps1 (script d'ouverture de session utilisateur), tous deux liés à la GPO eole\_script. Ces fichiers ont été générés lors de la phase d'instanciation de mon serveur Scribe pour automatiser le déploiement de certains composants.
- **Conséquence (Risque)** : Selon le framework MITRE ATT&CK, des changements non autorisés dans le SYSVOL peuvent être utilisés pour l'exécution de code malveillant, l'escalade de privilèges ou le maintien d'une persistance. Si un attaquant parvient à modifier l'un de ces scripts, il pourrait exécuter des commandes avec les privilèges "Système" sur toutes les machines du domaine lors de leur démarrage. Bien que ces scripts soient ici légitimes et liés à la configuration EOLE, toute modification non documentée par un administrateur doit faire l'objet d'une enquête immédiate pour vérifier l'intégrité de la posture de sécurité.



Voici mon analyse de l'indicateur d'exposition Purple Knight concernant les accès en écriture à la délégation RBCD sur mon contrôleur de domaine scribe.local :

### Write access to RBCD on DC (Sévérité Haute)

Cet indicateur recherche les utilisateurs qui ne font pas partie des groupes d'administration restreints (Domain Admins, Enterprise Admins, etc.) mais qui possèdent des droits d'écriture sur la délégation Kerberos basée sur les ressources (RBCD) des contrôleurs de domaine.

- **Explication (Cause)** : Mon audit a identifié que le contrôleur de domaine CN=ADDC,OU=Domain Controllers,DC=scribe,DC=local présente une permission critique. Un compte ou un groupe possède le droit GenericAll sur l'attribut msds-AllowedToActOnBehalfOfOtherIdentity de l'objet DC. Cette configuration permet à l'entité bénéficiaire de modifier qui est autorisé à usurper l'identité d'autres utilisateurs auprès de ce service.
- **Conséquence (Risque)** : Selon le framework MITRE ATT&CK, cette faille est extrêmement dangereuse car elle permet une **escalade de privilèges directe**. Un attaquant ayant pris le contrôle du compte disposant de ce droit d'écriture peut configurer la RBCD pour forcer le contrôleur de domaine à accepter une impersonnalisation. Il peut ainsi se faire passer pour n'importe quel utilisateur (même un administrateur du domaine) et prendre le contrôle total des services du DC, ce qui représente un impact substantiel sur la sécurité globale de mon annuaire.



#### SECURITY INDICATOR

#### Write access to RBCD on krbtgt account

IOE Found

82%

#### SEVERITY

High

#### WEIGHT

7

#### Security Frameworks

MITRE ATT&CK

- Credential Access

#### Description

This indicator looks for Write access on RBCD for the krbtgt account to users who are not in Domain Admins, Enterprise Admins and Built-in Admins groups.

#### Likelihood of Compromise

This setting enables configuring RBCD on the krbtgt account. An attacker that is able to gain Write access to RBCD for a resource can cause that resource to impersonate any user (except where delegation is explicitly disallowed). Write on RBCD is always a high privilege, but when it is on the krbtgt account, the impact is substantial because it allows the attacker to create TGS for krbtgt for any user, which can then be used as a TGT.

#### Result

Found 1 principals that can write to msds-AllowedToActOnBehalfOfOtherIdentity on krbtgt.

| Identity     | DistinguishedName                     | Access                               | Ignored |
|--------------|---------------------------------------|--------------------------------------|---------|
| S-1-5-32-548 | CN=krbtgt,CN=Users,DC=scribe,DC=local | Allow: GenericAll on: All Properties | False   |

Showing 1 of 1

#### Remediation Steps

Review the list and ensure that there are no unnecessary principals who can set resource-based constrained delegation on krbtgt.

## Write access to RBCD on krbtgt account (Sévérité Haute)

Cet indicateur recherche les utilisateurs ne faisant pas partie des groupes d'administration restreints qui possèdent des droits d'écriture sur la délégation Kerberos basée sur les ressources (RBCD) pour le compte krbtgt.

- **Explication (Cause) :** Mon audit a révélé qu'une entité possède le droit GenericAll sur l'attribut msds-AllowedToActOnBehalfOfOtherIdentity du compte CN=krbtgt,CN=Users,DC=scribe,DC=local. Cette configuration permet à un utilisateur non privilégié de modifier les paramètres de délégation sur ce compte extrêmement sensible, qui est le cœur du système d'authentification Kerberos.
- **Conséquence (Risque) :** Selon le framework MITRE ATT&CK, cette vulnérabilité est critique car elle permet à un attaquant de forcer le compte krbtgt à impersonnaliser n'importe quel utilisateur. En modifiant la RBCD sur ce compte, l'attaquant peut créer des tickets de service (TGS) pour le compte krbtgt, qui peuvent ensuite être utilisés comme des tickets de garantie (TGT). L'impact est considéré comme substantiel car cela donne potentiellement à l'attaquant la clé de voûte de la sécurité du domaine, lui permettant de générer des tickets d'accès pour n'importe quelle ressource de l'annuaire.